CONTEXTUALIZAÇÃO

O que é um scanner de vulnerabilidades?

E por que os relatórios dele viraram um problema.



Beatriz Machado · Cristhian Kapelinski · Guilherme Klauberg

UNIPAMPA · Inteligência Artificial Aplicada

PRIMEIRO PASSO

Vulnerabilidade é uma porta destrancada

Uma falha em um sistema que um atacante pode usar para invadir, roubar dados ou derrubar um serviço.

Software velho

Versão com falha conhecida

Senha padrão

O admin/admin que ninguém trocou

Porta aberta

Serviço exposto sem necessidade

O SCANNER

Um programa que procura as portas destrancadas

Uma ferramenta automática que examina os computadores de uma rede em busca de falhas já conhecidas.

1 Descobre
Quais máquinas e serviços existem

→

2 Testa
Contra falhas públicas catalogadas (CVE)

→

3 Relata
Gera um relatório, muitas vezes só em PDF

BENEFÍCIOS

E se não existisse scanner?

Alguém teria que procurar as falhas máquina por máquina.

SEM SCANNER

- Entrar em cada máquina
- Anotar programas, versões e portas
- Comparar com listas de falhas

COM O SCANNER

- Centenas de máquinas de uma vez
- Lista de falhas sempre atualizada
- Diz o que corrigir primeiro

EXEMPLOS

Alguns dos mais usados na área



OpenVAS

Gratuito, de código aberto



Nessus

Comercial, muito difundido



Qualys

Comercial, na nuvem



ZAP

Gratuito, foco em sites

Medium (CVSS: 5.0)
NVT: /doc directory browsable

Summary
The /doc directory is browsable. /doc shows the content of the /usr/doc directory and therefore it shows which programs and - important! - the version of the installed programs.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
`Vulnerable URL: http://metasploitable2.trabalho_vulnnet/doc/`

Solution:
Solution type: Mitigation
Use access restrictions for the /doc directory. If you use Apache you might use this in your access.conf:
<Directory /usr/doc> AllowOverride None order deny, allow deny from all allow from localhost </Directory>

Vulnerability Detection Method
Details: `/doc directory browsable`
OID:1.3.6.1.4.1.25623.1.0.10056
Version used: `2023-08-01T13:29:10Z`

References
`cve: CVE-1999-0678`
`url: http://www.securityfocus.com/bid/318`

UM RELATÓRIO REAL

Cada falha vira um achado

1. **O que é** · nome da falha
2. **Quão grave** · severidade
3. **Onde está** · endereço afetado
4. **Como corrigir** · solução

O PROBLEMA

Feito para ler, não para processar

1. Muitos relatórios, muitas páginas
2. Cada ferramenta no seu formato
3. Juntar e comparar é trabalho manual



O DETALHE · DESCRIÇÃO

Mesma informação, outro formato

OpenVAS Summary

2.1.34 Log 514/tcp

Log (CVSS: 0.0)
NVT: rsh Service Detection

Summary
Checks if the remote host is running a rsh service.
Note: The reporting takes place in a separate VT 'rsh Unencrypted Cleartext Login' (OID: 1.3.6.1.4.1.25623.1.0.100080).

Quality of Detection (QoD): 80%

Vulnerability Detection Result
`A rsh service is running at this port.`

Solution:

Log Method
Details: `rsh Service Detection`
OID:1.3.6.1.4.1.25623.1.0.108478
Version used: `2024-06-26T05:05:39Z`

Nessus Synopsis

10245 - rsh Service Detection

Synopsis

The rsh service is running on the remote host.

Description

The rsh service is running on the remote host. This service is vulnerable since data is passed between the rsh client and server in cleartext. A man-in-the-middle attacker can exploit this to sniff logins and passwords. Also, it may allow poorly authenticated logins without passwords. If the host is vulnerable to TCP sequence number guessing (from any network) or IP spoofing (including ARP hijacking on a local network) then it may be possible to bypass authentication.

Finally, rsh is an easy way to turn file-write access into full logins through the .rhosts or rhosts.equiv files.

Solution

Comment out the 'rsh' line in /etc/inetd.conf and restart the inetd process. Alternatively, disable this service and use SSH instead.

Risk Factor

High

CVSS v2.0 Base Score

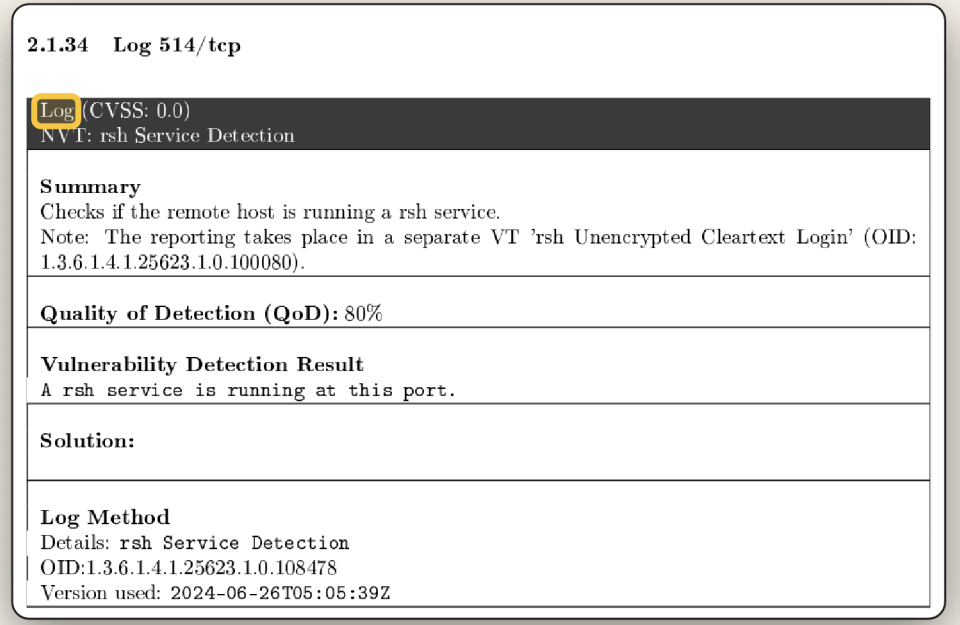
7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

References

O DETALHE · SEVERIDADE

Mesma informação, outro formato

OpenVAS Log



2.1.34 Log 514/tcp

Log (CVSS: 0.0)
NVT: rsh Service Detection

Summary
Checks if the remote host is running a rsh service.
Note: The reporting takes place in a separate VT 'rsh Unencrypted Cleartext Login' (OID: 1.3.6.1.4.1.25623.1.0.100080).

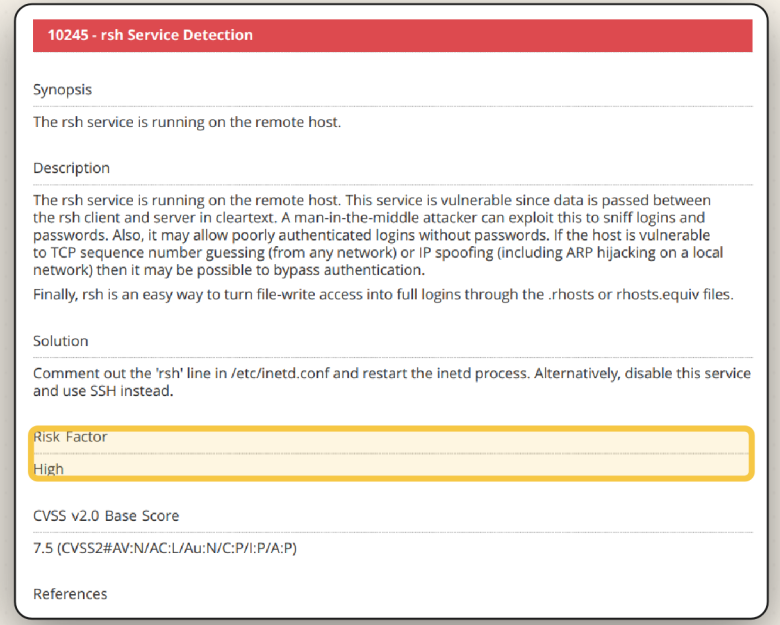
Quality of Detection (QoD): 80%

Vulnerability Detection Result
`A rsh service is running at this port.`

Solution:

Log Method
Details: `rsh Service Detection`
OID:1.3.6.1.4.1.25623.1.0.108478
Version used: `2024-06-26T05:05:39Z`

Nessus High



10245 - rsh Service Detection

Synopsis

The rsh service is running on the remote host.

Description

The rsh service is running on the remote host. This service is vulnerable since data is passed between the rsh client and server in cleartext. A man-in-the-middle attacker can exploit this to sniff logins and passwords. Also, it may allow poorly authenticated logins without passwords. If the host is vulnerable to TCP sequence number guessing (from any network) or IP spoofing (including ARP hijacking on a local network) then it may be possible to bypass authentication.

Finally, rsh is an easy way to turn file-write access into full logins through the .rhosts or rhosts.equiv files.

Solution

Comment out the 'rsh' line in /etc/inetd.conf and restart the inetd process. Alternatively, disable this service and use SSH instead.

Risk Factor

High

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

References

O DETALHE · NOME

Mesma informação, outro formato

OpenVAS `NVT: nome`

2.1.34 Log 514/tcp

Log (CVSS: 0.0)
NVT: rsh Service Detection

Summary
Checks if the remote host is running a rsh service.
Note: The reporting takes place in a separate VT 'rsh Unencrypted Cleartext Login' (OID: 1.3.6.1.4.1.25623.1.0.100080).

Quality of Detection (QoD): 80%

Vulnerability Detection Result
`A rsh service is running at this port.`

Solution:

Log Method
Details: `rsh Service Detection`
OID:1.3.6.1.4.1.25623.1.0.108478
Version used: `2024-06-26T05:05:39Z`

Nessus `plugin ID - nome`

10245 - rsh Service Detection

Synopsis

The rsh service is running on the remote host.

Description

The rsh service is running on the remote host. This service is vulnerable since data is passed between the rsh client and server in cleartext. A man-in-the-middle attacker can exploit this to sniff logins and passwords. Also, it may allow poorly authenticated logins without passwords. If the host is vulnerable to TCP sequence number guessing (from any network) or IP spoofing (including ARP hijacking on a local network) then it may be possible to bypass authentication.

Finally, rsh is an easy way to turn file-write access into full logins through the .rhosts or rhosts.equiv files.

Solution

Comment out the 'rsh' line in /etc/inetd.conf and restart the inetd process. Alternatively, disable this service and use SSH instead.

Risk Factor

High

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

References

NOSSA PROPOSTA

Do PDF para um formato único



→

PDF do OpenVAS

```
{
  "name": "rsh Service Detection",
  "severity": "LOG",
  "cvss": 0.0,
  "host": "172.30.1.1",
  "port": 514,
  "protocol": "tcp",
  "source": "openvas"
}
```

PDF do Nessus

```
{
  "name": "rsh Service Detection",
  "severity": "HIGH",
  "cvss": 7.5,
  "host": "172.30.1.1",
  "port": 514,
  "protocol": "tcp",
  "source": "nessus"
}
```

Formatos diferentes na entrada, **os mesmos campos na saída**.